

Northgate University

Information Security Risk Management Methodology

An ISO/IEC 27001:2013 aligned document · Internal Use Only

Document Reference	NGU-POL-4.1
Version	1.0
Classification	Internal Use Only
Issue Date	01 June 2026
Policy Owner	Chief Information Security Officer
Approved By	Information Governance Board
Next Review Date	01 June 2027
Parent Policy	Information Security Risk Management Policy (NGU-POL-IRM01)
Aligned Standard	ISO/IEC 27001:2013 — Clauses 6.1.2, 6.1.3; ISO/IEC 27005

1. Purpose

This methodology defines the process by which Northgate University ("the University") identifies, analyses, evaluates, and treats information security risk. It operationalises the Information Security Risk Management Policy (NGU-POL-IRM01) and provides the scales, scoring, and workflow that ensure risks are assessed consistently and repeatably across the University, in line with ISO/IEC 27001:2013 and the guidance of ISO/IEC 27005.

2. Scope

This methodology applies to all information security risk assessments performed across the University's information assets, systems, and services, whether conducted as part of the periodic assessment cycle or triggered by change. It is used by everyone who identifies, assesses, or treats information security risk.

3. Risk Management Process

Information security risk is managed through the following repeatable process. Each step is recorded in the information security risk register:

1. Establish the context and confirm the scope of the assessment.
2. Identify the information assets in scope and their owners.
3. Identify the threats and vulnerabilities applicable to each asset.
4. Assess likelihood and impact, and calculate the inherent risk score and level.
5. Evaluate each risk against the risk criteria.
6. Select and apply a treatment option for risks above appetite.
7. Reassess the residual risk after treatment.
8. Obtain formal risk-owner acceptance of the residual risk.
9. Record all risks in the risk register and monitor and review them on the defined cycle.

4. Asset Identification and Valuation

Each assessment begins by identifying the information assets in scope and the Information Asset Owner accountable for each. Assets are valued according to the potential harm to their confidentiality, integrity, and availability, using the University's information classification scheme. The most sensitive classification associated with an asset informs the impact ratings applied during assessment.

5. Likelihood Assessment

Likelihood is the probability that a threat will exploit a vulnerability within the assessment period. It is rated on a scale of 1 to 5:

Rating	Likelihood	Description
1	Rare	Very unlikely to occur; may happen only in exceptional circumstances (less than once in five years).
2	Unlikely	Could occur at some point but is not expected (roughly once every two to five years).
3	Possible	Might occur at some time (roughly once a year).
4	Likely	Expected to occur in most circumstances (several times a year).
5	Almost Certain	Expected to occur frequently, or is already occurring (monthly or more often).

6. Impact Assessment

Impact is the severity of harm to the University should the risk materialise, considering effects on confidentiality, integrity, availability, operations, legal and regulatory compliance, and reputation. It is rated on a scale of 1 to 5:

Rating	Impact	Description
1	Insignificant	Negligible effect; no service disruption, no data affected, and no regulatory or reputational consequence.
2	Minor	Limited, localised effect; minor disruption; only Internal Use Only information affected; readily recovered.
3	Moderate	Noticeable disruption; Restricted information affected; some financial or reputational impact; recoverable with effort.
4	Major	Significant disruption; Confidential or personal data affected; a reportable breach; notable legal, financial, or reputational harm.
5	Severe	Critical or prolonged disruption; large-scale loss of Confidential or personal data; serious regulatory penalty or harm to individuals; major reputational damage.

7. Risk Scoring and the Risk Matrix

The inherent risk score is calculated by multiplying likelihood by impact, producing a value between 1 and 25:

$$\text{Risk Score} = \text{Likelihood (1–5)} \times \text{Impact (1–5)}$$

The score is mapped to a risk level using the matrix below. Locate the row for the assessed impact and the column for the assessed likelihood; the cell shows the resulting risk score and level.

Risk = L × I	L1	L2	L3	L4	L5
5 – Severe	5 Low	10 Med	15 High	20 High	25 High
4 – Major	4 Low	8 Med	12 Med	16 High	20 High
3 – Moderate	3 Low	6 Low	9 Med	12 Med	15 High
2 – Minor	2 Low	4 Low	6 Low	8 Med	10 Med
1 – Insignificant	1 Low	2 Low	3 Low	4 Low	5 Low

Key: Low (1–6) · Medium (7–12) · High (13–25). Risk severity increases with both likelihood and impact.

8. Risk Evaluation Criteria

Each risk score is evaluated against the following criteria to determine the action required. These criteria are consistent with the risk appetite set out in the Risk Management Policy:

Risk Level	Risk Score (1–25)	Required Action
Low	1 – 6	Acceptable. Routine monitoring; treatment optional.
Medium	7 – 12	Tolerable. A treatment plan is recommended; the risk owner must be aware of and accept any residual risk.
High	13 – 25	Unacceptable without treatment. A documented treatment plan and formal risk-owner acceptance are mandatory; High risks are escalated to the Information Governance Board.

9. Risk Treatment

Risks that exceed the University's appetite are treated by selecting one of the following options:

- **Modify (reduce).** Apply or strengthen controls to reduce the likelihood and/or impact of the risk.
- **Retain (accept).** Knowingly accept the risk where it falls within appetite, with documented risk-owner approval.
- **Avoid.** Discontinue, or decide not to begin, the activity that gives rise to the risk.
- **Share (transfer).** Share the risk with a third party, for example through insurance or contractual arrangements.

For each risk to be modified, appropriate controls are selected — primarily from ISO/IEC 27001:2013 Annex A — and documented in a risk treatment plan. Selected controls are

reflected in the Statement of Applicability. The residual risk remaining after treatment is reassessed using the same likelihood and impact scales.

10. Risk Acceptance

Residual risk must be formally accepted by the relevant Information Asset Owner before a risk is considered managed. Residual risk rated Low may be accepted by the asset owner; residual risk rated Medium requires documented owner acceptance and awareness; residual risk rated High must be escalated to the Information Governance Board for decision. Accepted risks are recorded in the risk register with the name of the accepting owner and the date of acceptance.

11. Risk Register, Monitoring and Review

All identified risks — together with their scores, treatments, residual ratings, owners, and status — are recorded in the central information security risk register. The register is reviewed at least quarterly. Risks are monitored through to closure, the effectiveness of treatments is confirmed at review, and the risk profile and all High-rated risks are reported to the Information Governance Board each cycle.

12. Roles and Responsibilities

- **CISO / Information Security Risk Manager.** Owns this methodology, maintains the risk register, and facilitates assessments.
- **Information Asset Owners.** Provide asset, threat, and impact input; implement agreed treatment; and accept residual risk.
- **Control and System Owners.** Implement and operate the controls selected during treatment.
- **Information Governance Board.** Sets risk appetite, oversees the risk profile, and decides on High residual risks.
- **Internal Audit.** Provides independent assurance over the application of this methodology.

13. Related Documents and Standards

- Information Security Risk Management Policy (NGU-POL-IRM01)
- Information Classification Policy (NGU-POL-8.2)
- Statement of Applicability
- Information Security Risk Register
- ISO/IEC 27001:2013 — Clauses 6.1.2, 6.1.3, 8.2, 8.3
- ISO/IEC 27005:2018 (information security risk management)
- ISO 31000:2018 (risk management — principles and guidelines)

14. Document Review

This methodology is reviewed at least annually, or sooner following significant change to the University's risk environment or to the parent Risk Management Policy. The Chief Information Security Officer is responsible for initiating the review.

15. Document Version History

Version	Date	Author	Summary of Change
1.0	01 June 2026	Chief Information Security Officer	Initial issue. Defines the risk assessment scales, matrix, and workflow.